TP2 : Reconnaissance, balayage et débordement de tampon

(Date limite de remise: le 16 mars 2026 à 23h59)

Exercice 1 – Reconnaissance Web (4 points)

Dans cet exercice, vous allez utiliser les outils offerts par ce site Web : https://gaijin.at/en/tools/ ainsi que le **terminal** de votre système d'exploitation. Il vous faudra prendre une prise d'écran après chaque étape et l'inclure dans votre rapport.

Accéder à https://gaijin.at/en/tools/ puis:

1. Trouver l'outil qui vous donnera l'adresse IP du site Web www.course.com. Donner l'adresse IP qui s'affiche.
2. Trouver l'outil qui permet d'afficher l'entête (*header*) de la page d'accueil de ce site Web.
3. Quel est le type du serveur Web utilisé pour héberger ce site Web?
4. Trouver l'outil qui permet de donner les informations suivantes sur le domaine umontreal.ca:
    a. Date de création;
    b. Date d'expiration;
    c. Date de mise à jour;
    d. Nom et coordonnées du contact technique;
    e. Liste des serveurs de nom (*Name Server*).

Utiliser le **terminal** de votre système d'exploitation pour les questions suivantes :

5. Donner les délais correspondants à **dix** requêtes « **ping** » au serveur Web de la DESI (www.desi.umontreal.ca). Que constatez-vous? Donner une explication.
6. Même question que **(5)** mais avec le site Web www.google.ca.
7. Donner la liste des adresses IP des routeurs qui séparent votre ordinateur du serveur de www.google.ca ainsi que leur localisation géographique (vous pouvez utiliser un moteur de recherche comme Google pour trouver cette information).
8. Qu'est-ce qui se passe lorsqu'on réduit le nombre de sauts (*Hops*) à 2 par exemple? Expliquer.

Exercice 2 – Balayage (5 points)

Dans cet exercice, vous allez utiliser l'outil « Nmap » pour pratiquer le balayage (*scanning*) de serveurs distants. À partir de https://nmap.org/download.html, télécharger et installer Nmap sur votre ordinateur. Il s'agit ici de Nmap avec interface graphique pour Windows appelée « Zenmap ». Vous pouvez installer la version qui correspond à votre système d'exploitation

(comme macOS par exemple) mais il vous faudra adapter les instructions suivantes en conséquence. Il vous faudra inclure dans votre rapport une prise d'écran de « Zenmap » après chaque étape ainsi que la commande que vous avez exécutée. Démarrer « Zenmap » puis:

1. Dans le champ « Target », saisir « localhost » (machine locale) puis cliquer sur « Scan ». Donner la liste qui s'affiche dans l'onglet « Ports / Hosts ». Que constater-vous et comment l'expliquer?
2. Faites un balayage du serveur « **scanme.nmap.org** ». Utiliser un tableau pour représenter le résultat qui s'affiche dans l'onglet « Ports / Hosts » en décrivant le service associé à chaque port et en expliquant clairement l'état de chaque port.
3. En utilisant le résultat du balayage de la question **(2)**, expliquer l'information affichée dans l'onglet « Topology ».
4. Donner la commande pour balayer toutes les machines dans votre réseau local (à domicile par exemple). Combien de machines existent-ils dans ce réseau local et quels systèmes d'exploitation roulent-ils selon le résultat du balayage?
5. Donner (sans exécuter!) la commande nmap qui peut être utilisée pour balayer **dix** serveurs Web choisis aléatoirement sur Internet.

> ⚠️ **Le balayage (*scanning*) peut être considéré comme une activité illégale. Ainsi, il est déconseillé de l'effectuer sur une machine sans avoir obtenu l'autorisation préalable du propriétaire de celle-ci.**

Exercice 3 – Débordement de tampon (5 points)

Dans cet exercice, vous allez explorer une vulnérabilité de type débordement de tampon dans un code qui s'exécute sur un serveur. Il vous faudra inclure dans votre rapport une prise d'écran pour chaque question.

1. Installer la machine virtuelle qui contient la configuration nécessaire pour compléter cet exercice en suivant les instructions dans ce lien :
   https://github.com/seed-labs/seed-labs/blob/master/manuals/vm/seedvm-manual.md
   À partir de la machine virtuelle que vous venez d'installer, télécharger et décompresser le dossier qui contient les fichiers (code et configuration) nécessaires pour compléter cet exercice :
   https://seedsecuritylabs.org/Labs_20.04/Files/Buffer_Overflow_Server/Labsetup.zip
2. Désactiver les contremesures :
   a. Ouvrir un terminal et exécuter la commande suivante. De quelle contremesure s'agit-il?
      ```
      sudo /sbin/sysctl -w kernel.randomize_va_space=0
      ```

3. Le code vulnérable dans le fichier `stack.c` se trouve dans le dossier `server-code`. Compiler ce code en utilisant les commandes suivantes :
   `make`
   `make install`
   Ces commandes vont exécuter la commande de compilation suivante qui implique la désactivation d'une autre contremesure. De quelle contremesure s'agit-il?
   `gcc -DBUF_SIZE=$(L1) -o stack -z execstack -fno-stack-protector stack.c`
4. Dans la fenêtre *Terminal*, exécuter les commandes suivantes pour lancer les serveurs :

   ```
   dcbuild
   dcup
   ```

5. Dans une <u>nouvelle</u> fenêtre *Terminal*, exécuter la commande suivante. Expliquer le comportement dans la première fenêtre *Terminal*?
   `echo hello | nc 10.9.0.5 9090`
   `Appuyer sur les touches Ctrl+C`
6. Exécuter la commande suivante en utilisant le fichier « mauvaisfich.dat » fournis sur la page du cours dans Studium. Expliquer le comportement dans la première fenêtre *Terminal*.
   `cat mauvaisfich.dat | nc 10.9.0.5 9090`
7. Utiliser votre propre fichier pour obtenir le même comportement que la question précédente. Quel est le critère déterminant pour obtenir un comportement normal versus un comportement anormal? (Soyez précis)
8. Comment un pirate peut-il exploiter le comportement anormal pour pousser l'impact de cette vulnérabilité au maximum?

Remise du TP

- Ce travail compte pour 14 % de la note finale du cours.
- Date limite de remise : Le 16 mars 2026 à 23h59.
- Il est recommandé de compléter ce travail en équipe de 2 étudiants (maximum). Dans ce cas, un seul des coéquipiers doit remettre le travail alors que l'autre doit compléter et remettre la fiche **RemiseCoequipier.docx** via **Studium**.
- La remise doit se faire sur **Studium**. Aucune remise par courriel ne sera acceptée.
- Vous devez remettre un seul rapport (fichier PDF) qui, en plus des réponses, doit contenir les noms des auteurs.
- La non-remise électronique (volontaire ou par erreur) est sanctionnée par la note 0.
- Pour toutes questions concernant ce travail pratique, envoyer un courriel à l'équipe du cours **hicham.mazouzi@umontreal.ca** et **a.belbekkouche@umontreal.ca**.

Bon travail !